SECUREAUDIT PRO

DISCOVER VULNERABILITIES • STRENGTHEN SECURITY • PROTECT DIGITAL ASSETS

CONFIDENTIAL TLP:AMBER
SECURITY ASSESSMENT REPORT

Ref: SAP-17BED978

Web Application Vulnerability Assessment & Penetration Testing Report

A formal penetration testing and security assessment evaluating OWASP Top 10:2025 risks, perimeter network ports, cryptographic parameters, sensitive resource exposures, and step-by-step defensive remediation countermeasures.

Target Website Asset:	**https://httpbin.org**	**Security Posture Score:**	**65.7 / 100**
Target Domain / Host:	**httpbin.org**	**Overall Security Rating:**	**Grade C (Elevated Risk)**
Assessment Profile:	Comprehensive VAPT Assessment	**Total Vulnerabilities:**	**9 Identified**
Perimeter Exposure:	**2 Open Ports Probed**	**Critical / High Findings:**	**1 Critical/High**
Assessment Completed:	November 07, 2026 - 22:48 UTC	**Compliance Standard:**	OWASP Top 10:2025 / NIST 800-115
Evaluation Engine:	SecureAudit Pro Security Engine v2.0	**Classification:**	STRICTLY CONFIDENTIAL

CRITICAL	HIGH	MEDIUM	LOW	INFO	TOTAL
0	1	4	2	2	9

Notice of Confidentiality: This document contains proprietary security analysis and confidential vulnerability intelligence. Unauthorized distribution or duplication is strictly prohibited. Intended exclusively for technical remediation by authorized personnel.

1. Executive Summary & Assessment Methodology

SecureAudit Pro performed an automated, non-destructive Vulnerability Assessment and Penetration Testing (VAPT) audit against the web application hosted at **https://httpbin.org** on **November 07, 2026 - 22:48 UTC**. The primary goal of this assessment was to discover technical weaknesses across the target perimeter, identify OWASP Top 10:2025 vulnerabilities, evaluate cryptographic posture, probe for exposed sensitive files, and deliver production-ready, prioritized remediation countermeasures.

Security Posture Overview: The target achieved an overall security score of **65.7 out of 100**, corresponding to **Grade C (Elevated Risk)**. A total of **9 vulnerabilities** were confirmed, including **0 Critical**, **1 High**, **4 Medium**, and **2 Low** severity issues. Immediate remediation of Critical and High findings is strongly advised to prevent unauthorized data exposure, session compromise, or network-level adversary-in-the-middle attacks.

Audit Standards & Framework Alignment

Standard / Framework	Scope & Evaluation Method	Target Assessment Status
OWASP Top 10:2025	Broken Access Control, Security Misconfiguration, Injection, SSRF, Crypto Failures	**Evaluated & Audited**
OWASP API Security 2023	Broken Object Level Auth, Unrestricted Resource Consumption, Rate Limiting	**Evaluated & Audited**
RFC 9110 / RFC 8446	HTTP/1.1 & HTTP/2 Security Headers, TLS 1.2/1.3 Handshake, Cipher Suite Security	**Handshake Verified**
Perimeter Port Discovery	TCP connect auditing on Web (80, 443, 8080) and Infrastructure (3306, 6379, 27017) ports	**Perimeter Scanned**

2. Target Technology Stack & Cryptographic Profile

Detected Component	Category	Version / Detail	Security Implication
React	Frontend Framework	Detected	Identified via passive response fingerprints and script tags.
jQuery	JavaScript Library	Detected	Identified via passive response fingerprints and script tags.
SSL/TLS Protocol	Transport Security	**TLSv1.3**	Negotiated Cipher: `TLS_AES_256_GCM_SHA384`
X.509 Certificate	Identity & Trust	Remaining: **87 Days**	Valid root certificate authority chain.

3. Network Perimeter & Open Ports Discovery

Network perimeter discovery probes identify exposed TCP listening ports, banner versions, and services. Exposing internal application listeners, database ports (MySQL, Redis, MongoDB), or cleartext administration services significantly elevates perimeter attack surface.

Port / Proto	Service	Description	Daemon / Banner String	Exposure Risk
`Port 80 / TCP`	**HTTP**	Web Server	`HTTP/1.0 400 Bad Request`	**INFO**

Port 443 / TCP	**HTTPS**	Encrypted Web Server (TLS)	Open TCP Service (HTTPS)	**INFO**

4. OWASP Top 10:2025 Threat Taxonomy Compliance

Category Code	Threat Category Name	Primary Evaluation Focus	Compliance Status
A01:2025	**Broken Access Control**	IDOR, Path Traversal, Admin Route Exposure	**NON-COMPLIANT (2 Issues)**
A02:2025	**Security Misconfiguration**	Missing Headers, Default Credentials, Server Banners	**NON-COMPLIANT (5 Issues)**
A03:2025	**Software Supply Chain Failures**	Outdated Libraries, Fingerprinted Server Daemons	**COMPLIANT (Clean)**
A04:2025	**Cryptographic Failures**	Weak Cryptography, Deprecated TLS, Insecure Transport	**NON-COMPLIANT (1 Issues)**
A05:2025	**Injection Weaknesses**	SQLi, Command Injection, Reflected Parameter Flaws	**COMPLIANT (Clean)**
A06:2025	**Insecure Design**	Missing Rate Limiting, Credential Stuffing Exposure	**NON-COMPLIANT (1 Issues)**
A07:2025	**Authentication Failures**	Session Management, Brute Force, Insecure Cookies	**COMPLIANT (Clean)**
A08:2025	**Software & Data Integrity**	Unvalidated Redirects, Subresource Integrity (SRI)	**COMPLIANT (Clean)**
A09:2025	**Logging & Monitoring Failures**	Error Stack Trace Exposure, Debug Disclosure	**COMPLIANT (Clean)**
A10:2025	**Server-Side Request Forgery**	SSRF Prone Endpoints, Internal IP Resolution	**COMPLIANT (Clean)**

5. Technical Vulnerability Findings & Actionable Remediation

This section details each confirmed security vulnerability, providing technical root-cause analysis, business impact evaluation, observed technical evidence traces, step-by-step code and server configuration countermeasures, and verification commands.

SEC-001: Missing Strict-Transport-Security (HSTS) Header [MEDIUM]

OWASP Category:	A04:2025 - Cryptographic Failures	**CWE Reference:**	**CWE-319**
CVSS v3.1 Score:	**5.3 / 10.0**	**Confidence Level:**	Confirmed
Affected Scope / URL:	`https://httpbin.org/`	**Parameter / Port:**	Perimeter / Network

Vulnerability Description & Root Cause:
The HTTP Strict-Transport-Security (HSTS) header is missing. Without HSTS, browsers may allow insecure HTTP connections susceptible to man-in-the-middle (MITM) downgrade attacks.

Security & Business Impact:
Attackers on the same network can intercept unencrypted HTTP traffic and strip SSL via SSLStrip attacks.

Observed Technical Evidence & Trace:
```
Headers checked on https://httpbin.org/. strict-transport-security header was not returned.
```

Recommended Countermeasures & Step-by-Step Remediation:
1. In Nginx: add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;
2. In Apache: Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"
3. In Django settings.py: SECURE_HSTS_SECONDS = 31536000, SECURE_HSTS_INCLUDE_SUBDOMAINS = True, SECURE_HSTS_PRELOAD = True

SEC-002: Missing Content-Security-Policy (CSP) Header [MEDIUM]

OWASP Category:	A02:2025 - Security Misconfiguration	**CWE Reference:**	**CWE-1021**
CVSS v3.1 Score:	**6.1 / 10.0**	**Confidence Level:**	Confirmed
Affected Scope / URL:	`https://httpbin.org/`	**Parameter / Port:**	Perimeter / Network

Vulnerability Description & Root Cause:
Content-Security-Policy (CSP) is an effective defense-in-depth header against Cross-Site Scripting (XSS), data injection, and clickjacking.

Security & Business Impact:
Increases susceptibility to reflected, stored, or DOM-based XSS attacks, as malicious scripts are allowed to execute without origin restrictions.

Observed Technical Evidence & Trace:
```
Headers on https://httpbin.org/ lacked a content-security-policy header.
```

Recommended Countermeasures & Step-by-Step Remediation:
1. Configure a strict Content-Security-Policy header in your reverse proxy:
Nginx: add_header Content-Security-Policy "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; object-src 'none'; frame-ancestors 'none'; base-uri 'self';" always;
Apache: Header always set Content-Security-Policy "default-src 'self'; script-src 'self'; object-src 'none'; frame-ancestors 'none';"
2. In Django: Configure django-csp middleware with CSP_DEFAULT_SRC = ("'self'",)
3. In Node.js / Express: Use helmet.contentSecurityPolicy().

SEC-003: Missing Clickjacking Protection (X-Frame-Options / frame-ancestors) [MEDIUM]

OWASP Category:	A02:2025 - Security Misconfiguration	**CWE Reference:**	**CWE-1021**
CVSS v3.1 Score:	**5.4 / 10.0**	**Confidence Level:**	Confirmed
Affected Scope / URL:	`https://httpbin.org/`	**Parameter / Port:**	Perimeter / Network

Vulnerability Description & Root Cause:

Neither X-Frame-Options nor CSP frame-ancestors is present. The page can be embedded into an attacker's iframe, leading to Clickjacking (UI redressing).

Security & Business Impact:

Attackers can trick users into performing unauthorized actions by overlaying deceptive visual elements over the legitimate application.

Observed Technical Evidence & Trace:

```
No X-Frame-Options header or CSP frame-ancestors found on https://httpbin.org/
```

Recommended Countermeasures & Step-by-Step Remediation:

1. In Nginx: add_header X-Frame-Options "DENY" always;
2. In Apache: Header always set X-Frame-Options "DENY"
3. In Django settings.py: X_FRAME_OPTIONS = 'DENY'
4. Or specify CSP: Content-Security-Policy: frame-ancestors 'none';

SEC-004: Missing or Weak Referrer-Policy Header [LOW]

OWASP Category:	A02:2025 - Security Misconfiguration	**CWE Reference:**	**CWE-116**
CVSS v3.1 Score:	**2.6 / 10.0**	**Confidence Level:**	Confirmed
Affected Scope / URL:	`https://httpbin.org/`	**Parameter / Port:**	Perimeter / Network

Vulnerability Description & Root Cause:

The Referrer-Policy header is missing or configured with a weak policy that leaks URLs and query parameters to third-party domains.

Security & Business Impact:

Sensitive session tokens, reset hashes, or internal IDs in URL query parameters can leak to external analytics or linked sites.

Observed Technical Evidence & Trace:

```
Received referrer-policy: None
```

Recommended Countermeasures & Step-by-Step Remediation:

1. In Nginx: add_header Referrer-Policy "strict-origin-when-cross-origin" always;
2. In Apache: Header always set Referrer-Policy "strict-origin-when-cross-origin"
3. In Django settings.py: SECURE_REFERRER_POLICY = 'strict-origin-when-cross-origin'
4. In Express.js: app.use(helmet.referrerPolicy({ policy: 'strict-origin-when-cross-origin' }));

SEC-005: Missing Permissions-Policy Header [INFO]

OWASP Category:	A02:2025 - Security Misconfiguration	**CWE Reference:**	**CWE-16**
CVSS v3.1 Score:	**1.5 / 10.0**	**Confidence Level:**	Confirmed
Affected Scope / URL:	`https://httpbin.org/`	**Parameter / Port:**	Perimeter / Network

Vulnerability Description & Root Cause:

The Permissions-Policy header allows web developers to restrict browser features and APIs (geolocation, camera, microphone, payment).

Security & Business Impact:

Third-party embedded scripts or iframes could potentially request hardware or browser permissions without restrictions.

Observed Technical Evidence & Trace:

```
Headers on https://httpbin.org/ lacked permissions-policy header.
```

Recommended Countermeasures & Step-by-Step Remediation:

1. In Nginx: add_header Permissions-Policy "camera=(), microphone=(), geolocation=(), payment=()" always;
2. In Apache: Header always set Permissions-Policy "camera=(), microphone=(), geolocation=(), payment=()"
3. In Django: Set header in custom middleware or reverse proxy.

SEC-006: Missing security.txt Responsible Disclosure Policy [INFO]

OWASP Category:	A02:2025 - Security Misconfiguration	**CWE Reference:**	**CWE-16**
CVSS v3.1 Score:	**0.0 / 10.0**	**Confidence Level:**	Confirmed
Affected Scope / URL:	`https://httpbin.org/.well-known/security.txt`	**Parameter / Port:**	Perimeter / Network

Vulnerability Description & Root Cause:

The website does not publish a security.txt file (RFC 9116) to guide ethical security researchers.

Security & Business Impact:

Legitimate security researchers may struggle to report discovered vulnerabilities securely.

Observed Technical Evidence & Trace:

```
HTTP 404 at https://httpbin.org/.well-known/security.txt. Content preview: <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN"> <title>404 Not Found</title> <h1>Not Found</h1> <p>The requested
```

Recommended Countermeasures & Step-by-Step Remediation:

Publish a security.txt file at /.well-known/security.txt with security contact details and PGP key.

SEC-007: Missing HTTP Request Rate Limiting Defense [LOW]

OWASP Category:	A06:2025 - Insecure Design	**CWE Reference:**	**CWE-799**
CVSS v3.1 Score:	**3.7 / 10.0**	**Confidence Level:**	Low
Affected Scope / URL:	`https://httpbin.org/`	**Parameter / Port:**	Perimeter / Network

Vulnerability Description & Root Cause:

No rate limiting controls or standard RateLimit headers (X-RateLimit-Limit, RateLimit-Remaining) were detected during burst requests to the target endpoint.

Security & Business Impact:

Leaves application endpoints vulnerable to automated credential brute forcing, API denial of service, and excessive cloud resource consumption.

Observed Technical Evidence & Trace:

```
Five consecutive rapid HEAD requests were accepted with HTTP 200 without rate-limit throttling headers.
```

Recommended Countermeasures & Step-by-Step Remediation:

1. In Nginx: Configure request rate limiting zone:
limit_req_zone $binary_remote_addr zone=api_limit:10m rate=10r/s;
location /api/ {
limit_req zone=api_limit burst=20 nodelay;
}
2. In Django REST Framework: Configure AnonRateThrottle and UserRateThrottle in settings.py.
3. In Express.js: Use express-rate-limit middleware.
4. Verification: Send 25 consecutive requests in a loop; verify server returns HTTP 429 Too Many Requests.

SEC-008: Insecure CORS Policy: Arbitrary Origin Reflection [HIGH]

OWASP Category:	A01:2025 - Broken Access Control	**CWE Reference:**	**CWE-942**
CVSS v3.1 Score:	**8.1 / 10.0**	**Confidence Level:**	Confirmed
Affected Scope / URL:	`https://httpbin.org/`	**Parameter / Port:**	Perimeter / Network

Vulnerability Description & Root Cause:

The application dynamically reflects the request Origin header into Access-Control-Allow-Origin: https://vulnerability-test-probe.example.org with Access-Control-Allow-Credentials: true.

Security & Business Impact:

Enables malicious third-party websites to make authenticated cross-origin requests and read private user data or sensitive API responses.

Observed Technical Evidence & Trace:

```
Sent 'Origin: https://vulnerability-test-probe.example.org' -> Received 'Access-Control-Allow-Origin:
https://vulnerability-test-probe.example.org' and 'Access-Control-Allow-Credentials: true'
```

Recommended Countermeasures & Step-by-Step Remediation:

Replace dynamic reflection with a strict allowlist of explicitly trusted domain origins. Never reflect untrusted origins alongside credentials.

SEC-009: Insecure CORS Policy: 'null' Origin Permitted [MEDIUM]

OWASP Category:	A01:2025 - Broken Access Control	**CWE Reference:**	**CWE-942**
CVSS v3.1 Score:	**5.7 / 10.0**	**Confidence Level:**	Confirmed
Affected Scope / URL:	`https://httpbin.org/`	**Parameter / Port:**	Perimeter / Network

Vulnerability Description & Root Cause:

The application trusts the 'null' origin. Sandboxed iframes, local files, and data: URIs produce a 'null' origin.

Security & Business Impact:

An attacker can host a sandboxed iframe that inherits a 'null' origin to bypass cross-origin restrictions and interact with the target API.

Observed Technical Evidence & Trace:

```
Sent 'Origin: null' -> Received 'Access-Control-Allow-Origin: null'
```

Recommended Countermeasures & Step-by-Step Remediation:

Do not include 'null' in Access-Control-Allow-Origin allowlists.

6. Remediation Roadmap & Priority Matrix

Remediation Window	Target Severity	Recommended Countermeasure Strategy
Immediate (0 – 48 Hours)	**Critical & High**	• Immediately close or firewall exposed database / management ports (Redis 6379, MySQL 3306, Telnet 23). • Enforce HTTPS and update expired or untrusted SSL/TLS certificates. • Secure administrative interfaces behind strict VPN and role-based authentication.
Short-Term (1 – 2 Weeks)	**Medium Severity**	• Implement missing security headers: Strict-Transport-Security (HSTS), Content-Security-Policy (CSP), and X-Frame-Options. • Enforce Secure, HttpOnly, and SameSite flags on all authentication and session cookies. • Restrict CORS Access-Control-Allow-Origin to trusted domains only.
Maintenance (30 Days)	**Low & Informational**	• Suppress Server, X-Powered-By, and framework version disclosure banners. • Configure SPF, DKIM, and DMARC DNS policies to prevent email spoofing. • Schedule continuous recurring security regression assessments.

Assessment Attestation:	Report Cryptographic Fingerprint:
Conducted by SecureAudit Pro Automated VAPT Platform. Auditor: Lead Security Analyst (6aea3e3628cd65624c715687) Date: November 07, 2026 - 22:48 UTC	`SHA-256 Digest: 9ce417bed978a8e9f5f7bb504e18` `Scope: httpbin.org | Status: Verified Formal Audit`